

Vulnerability Management Policy

Organization: Techno Optics LLC (operating Taxottic) **Document version:** 1.0 **Effective date:** 2026-05-04
Owner: Information Security Lead, Techno Optics LLC **Review cadence:** Annually, and after any material change to the application or to a third-party processor

1. Purpose

This Vulnerability Management Policy ("Policy") describes how Techno Optics LLC discovers, prioritises, remediates, and tracks security vulnerabilities in the Taxottic application and its supporting infrastructure. It implements the security commitments made in our Information Security Policy and gives operations personnel a clear, auditable rule for handling vulnerabilities at every layer of the stack.

The Policy applies to all production and pre-production environments operated by Techno Optics LLC, including third-party services that hold customer data on our behalf.

2. Scope

This Policy covers:

- The Taxottic web application (`taxottic.com` and `hq.taxottic.com`) hosted on Vercel.
- The Postgres database, edge functions, and storage operated by Supabase.
- All open-source libraries and direct dependencies listed in `package.json` and `package-lock.json` .
- The runtime platform (Node.js / Next.js) and the underlying serverless infrastructure managed by Vercel and AWS.
- The bank-data integration with Plaid and the AI integration with Anthropic.
- Personnel devices used to access production systems.

3. Detection and Scanning

We rely on layered, automated scanning. Each layer runs on a defined cadence and routes findings into a single triage queue:

Layer	Tool / mechanism	Frequency
Direct npm dependencies	<code>npm audit</code> on every <code>npm install</code> and on every CI run	Every commit / pull-request
Indirect npm dependencies	GitHub Dependabot — security updates and version updates	Continuous; PRs auto-opened
GitHub repository	GitHub code scanning (CodeQL) for JavaScript/TypeScript	Continuous on default branch and PRs
Container / runtime images	Vercel-managed Node.js runtime is patched by Vercel; we track the runtime version via <code>engines</code> in <code>package.json</code>	Vercel-managed; we re-deploy after each Vercel runtime upgrade
Database engine	Supabase-managed Postgres is patched by Supabase; we monitor Supabase status notices	Supabase-managed; we re-test after major-version upgrades
TLS configuration	Mozilla Observatory + SSL Labs spot-check	Quarterly
Web application	Manual review of new auth/payment flows; targeted penetration testing engaged when budget permits, at least once per major release	Per-release

Public vulnerability advisories that affect our stack (Node.js CVEs, Next.js advisories, Plaid security bulletins, Supabase status notices) are also tracked via mailing lists and the relevant vendor status pages.

4. Prioritisation

Findings are scored and triaged according to the following severity model, derived from the CVSS base score and exploitability context:

Severity	Definition	SLA to remediate
Critical	Remote code execution, authentication bypass, mass-PII disclosure, or any actively exploited vulnerability affecting production	7 days
High	Privileged access, sensitive-data disclosure, or significant integrity / availability impact, no public exploit yet	30 days
Medium	Limited disclosure, partial denial of service, or vulnerabilities in non-production code paths	60 days
Low	Defence-in-depth weaknesses, deprecated dependencies, hardening recommendations	90 days, or batched into the next minor-release window

Severity is set by the Information Security Lead at triage. Compensating controls (e.g. WAF rule, feature flag, network isolation) may permit a lower severity rating with documented justification.

5. Remediation

For each finding above the "Low" tier we:

1. **Reproduce.** Confirm the vulnerability is present and exploitable in our environment.
2. **Assign.** The Information Security Lead opens a tracking issue and assigns an owner.
3. **Patch.** Upgrade the affected dependency, apply a code fix, or apply a compensating control. Patches are deployed through the normal review-and-deploy pipeline; emergency patches still require code review.
4. **Verify.** Re-run the relevant scanner or test to confirm the finding is closed.
5. **Document.** Record the finding ID, root cause, action taken, and verification evidence in the operations runbook.

For Low-tier findings, the same workflow is applied at the next minor-release window unless a Low cluster materially weakens defence in depth.

6. Patch Management

- **Direct dependency upgrades** are batched weekly via Dependabot pull requests. Each PR runs the full lint + type-check + test suite before merge.
- **Major version upgrades** of Next.js, React, Supabase JS, and the Plaid SDK are scheduled, reviewed in a dedicated PR, and deployed during a low-traffic window.
- **Runtime upgrades** (Node.js) follow the version Vercel pins; we re-deploy promptly after a Vercel platform announcement that includes a security patch.
- **Database upgrades** are coordinated with Supabase; we test against a Supabase staging branch before merging in production.

7. Penetration Testing

We commission targeted application penetration testing at least once per major release of the consumer product, and any time we materially change the authentication or banking-integration code paths. Tests are scoped to cover authentication, authorisation, banking data flows, and storage. Findings are entered into the same triage queue as automated findings and are remediated under the same SLAs.

8. Coordinated Disclosure and Bug Reports

Reports from external researchers or customers are sent to security@taxottic.com. We acknowledge within **2 business days** and work with the reporter under a coordinated-disclosure model. We do not pursue legal action against good-faith researchers who follow the published disclosure guidance at

<https://taxottic.com/legal/security>.

9. Personnel and Endpoints

- Personnel devices used to access production systems run a current operating system version with full-disk encryption enabled and an active malware-protection product (Microsoft Defender or equivalent on Windows; the system Gatekeeper / XProtect on macOS).
- Personnel apply OS and browser updates within 7 days of release for security patches.
- Personnel revoke their own production credentials immediately on departure; the Information Security Lead audits this within 24 hours.

10. Metrics and Reporting

The Information Security Lead reports the following metrics at each quarterly review:

- Open findings by severity.
- Mean time to remediate for each severity tier.
- Number of dependency upgrade PRs merged in the quarter.
- Number of advisories tracked and closed.

Metrics are recorded in the operations runbook.

11. Exceptions

Any exception to this Policy must be approved in writing by the Information Security Lead and recorded in the operations runbook with a justification, scope, and expiry date. Exceptions are reviewed at the next quarterly compliance check.

12. Contact

Vulnerability reports: security@taxottic.com. Policy questions: privacy@taxottic.com.

Information Security Lead, Techno Optics LLC.